

CareerBuddies Founder Ledger

Complete Functional QA Audit Report

Audit date: 2026-10-09 · Project: CareerBuddies Founder Ledger · Commit audited: 8f0fa37 (branch `claude/compassionate-bardeen-9zxrjv`) · Auditor: Claude (automated + scripted browser/API testing) · No application code was modified.

1. Executive summary and readiness

Readiness: PASS WITH ISSUES. Money calculations, Option C reimbursements, settlement maths, approval rules, authorization, audit trail and persistence were verified by execution and behaved correctly, including backend enforcement of approval rules and role checks. **No Critical or High defects were found.** Six failing checks (five distinct defects) were found: 2 Medium (gateway keeps a stale API address after an API+DB restart → lasting 502 until the web container is restarted; expired sessions leave a stuck "Authentication required" page instead of returning to login) and 3 Low (320 px overflow on the transactions list [fails two page checks], console 401 noise on the login page, rate-limiter log errors). Nothing was fixed, per the audit rules.

Tests planned	200 (188 scripted rows + 12 documented not-testable items)
Tests executed	186
Passed	180
Failed	6
Blocked	0
Not tested	14 (2 design observations not asserted + 12 items in section 8)

"Executed" counts 130 API/security/persistence/static checks, 51 real-browser checks (Chromium, 4 viewports for each page), 1 log check and 4 automated-suite/typecheck/build runs. The existing 403 server and 101 client unit tests were also run (counted once each as AUTO rows, not 504 separate tests).

2. Environment and limitations

- All testing ran in a cloud sandbox against an **isolated throw-away Docker stack** (project `cbqa`, port 8090, fresh MongoDB 7 volume, built from commit 8f0fa37). The user's real stack on :8080 and its data were not modified. Test data (QA-prefixed) exists only in the throw-away stack.
- Tools: Node scripts calling the real HTTP API with cookie sessions; Playwright + Chromium for the UI; direct MongoDB queries via `mongosh` inside the container; the repository's own Vitest suites.
- Not the user's Windows PC; development cookie settings; Chromium only; sandbox clock 2026-10-09. See section 8 for everything that was not tested.
- Test-harness issues found and corrected during the audit (wrong test ordering, shared rate-limit, pagination of the approvals queue with many pending test items) were harness defects, not application defects; every reported failure below was reproduced against the final harness.

3. Modules audited and module-wise results

Module	Executed	Passed	Failed
Approval rules	1	1	0
Approvals	11	11	0
Audit log	7	7	0
Auth	1	0	1
Authentication	13	13	0
Authorization	3	3	0
Automated tests	2	2	0
Branding & logo	3	3	0
Business profile	2	2	0
Calculation & reporting	1	1	0
Categories	12	12	0

Console errors	1	0	1
Currency & regional	2	2	0
Dashboard	2	2	0
Dashboard preferences	1	1	0
Dead controls	2	2	0
Error states	1	1	0
Founders	7	7	0
In-memory state	1	1	0
Page	10	8	2
Persistence	7	6	1
Portal entry	1	1	0
Recurring	10	10	0
Recurring payment settings	1	1	0
Reimbursement	8	8	0
Reports	6	6	0
Responsive	1	1	0
Route protection	4	4	0
Security & errors	9	9	0
Server logs	1	0	1
Settings	16	16	0
Settlement preferences	1	1	0
Settlements	10	10	0
Static checks	2	2	0
Transactions	23	23	0
UI quality	2	2	0
User access	1	1	0

4. Failures: reproduction, expected vs actual

PERS-07 — Restart API and database together Medium

Reproduce:

1. ``docker compose -p`

`up -d`` and confirm `http://localhost:8090/api/health = 200`.

2. Run ``docker compose -p`

`restart server mongo``.

3. Poll `http://localhost:8090/api/health` for 70 s.

4. Read client logs: ``connect() failed (111) ... upstream http://172.19.0.3:4000`` while the API is now at 172.19.0.4.

5. ``docker compose restart client`` → health returns 200.

Expected: The web gateway reconnects to the API as soon as it is healthy.

Actual: HTTP 502 Bad Gateway for the whole 70 s (36 logged upstream failures) and indefinitely until the client container is restarted. (Restarting only the API kept its IP and recovered: PERS-06 PASS.)

Impact: Availability after partial restart. No data loss.

UI-102 — Transactions page at 320 px width Low

Reproduce:

1. Sign in; set viewport 320×640.

2. Open /transactions with at least one transaction.

Expected: No horizontal scrolling.

Actual: document scrollWidth exceeds viewport by 21 px; the amount line in the mobile transaction card (``p.whitespace-nowrap.font-bold.tabular-nums``) ends at x=341. See screenshot.

Impact: Only at ≤ 320 px.

UI-109 — Add Transaction route at 320 px Low

Reproduce:

Open /transactions/new at 320×640.

Expected: No horizontal scrolling.

Actual: Same 21 px overflow (the Transactions list behind the dialog; the dialog itself fits).

Impact: Same root cause as UI-102.

UI-110 — Login page console errors Low

Reproduce:

Open /login signed-out with DevTools console open.

Expected: No console errors.

Actual: Two console errors: 401 GET /api/auth/me and 401 POST /api/auth/refresh (expected probes, but logged as errors).

Impact: Cosmetic/noise.

UI-409 — Session lost while the app is open Medium

Reproduce:

1. Sign in, open /dashboard.
2. Clear the session cookies (simulates expiry/server-side logout).
3. Click "Founders" in the sidebar.

Expected: App returns to the login page (optionally with "session expired").

Actual: URL stays /founders; page shows "Authentication required [Retry]" with the full sidebar still visible; Retry cannot succeed. Backend calls: 401 financial-positions, 401 approvals, 401 refresh. See screenshot.

Impact: User must navigate manually; no data exposure.

OBS-01 — Server log noise Low

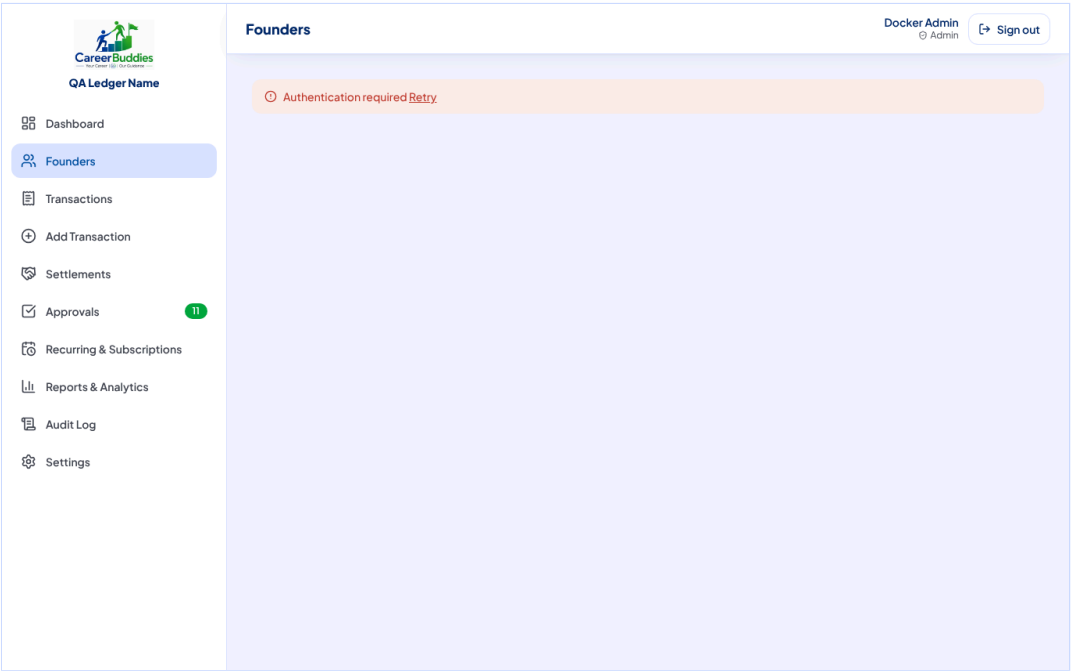
Reproduce:

Use the app normally (write endpoints), then `docker compose logs server`.

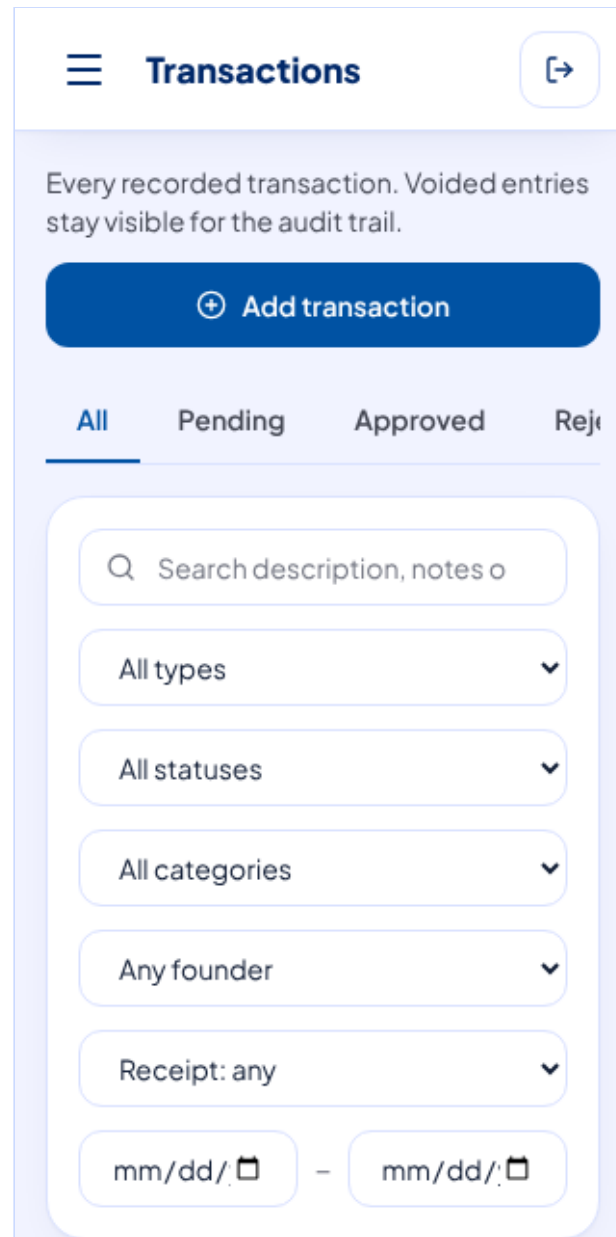
Expected: No framework validation errors in logs.

Actual: 33 x `ValidationError ERR\_ERL\_CREATED\_IN\_REQUEST\_HANDLER` from express-rate-limit (limiters created lazily inside request handlers). Limiters still work (SEC-09 429 verified).

Impact: Log noise; could hide real errors.



Evidence UI-409: stuck page after session loss



Evidence UI-102: 320 px viewport (amount in card exceeds the viewport by 21 px; Rejected tab scrolls inside its own row)

5. Security and data-integrity findings

- **Verified good:** every protected endpoint returns 401 unauthenticated (12 reads, 7 writes); 9 admin-only calls return 403 to founders; no privilege escalation by role patch; tampered and post-logout cookies rejected; disabled users lose access immediately; passwords stored as hashes (verified in MongoDB); cookies HttpOnly + SameSite=Strict; foreign-Origin write returns 403; CORS echoes only the site origin; security headers (nosniff, SAMEORIGIN) present; malformed JSON, oversize

body, NoSQL operators, mass-assignment fields, spoofed images, over-long inputs all rejected; login rate limiting returns 429; CSV formula injection neutralised; script text in descriptions rendered inert in 6 pages (no dialog, no injected element); receipts and photos need sign-in.

- **Financial integrity verified:** ₹1,000.01 splits to 33,334/33,334/33,333; pending/rejected/voided never counted; Σ net positions = 0; reconciliation PASS after approve, partial/multiple reimbursements, void, settlement record/confirm/reverse; excess reimbursement and over-owed settlements rejected; pending reservations count; an expense with active reimbursements cannot be voided; voiding a reimbursement restores capacity; dashboard, report, category, monthly and annual totals agree exactly; no hard deletes anywhere; stale versions return 409; replayed idempotency keys and 6 concurrent recurring records create exactly one transaction.
- **Observation (Medium, design):** an over-settlement can still be approved through the generic Add Transaction form (engine flags it as reconciliation REVIEW). Settlement guard rails apply only to the guided Record Payment flow.
- **Observation:** self-approval defaults ON and any founder can approve any pending item; both are policy choices, and the backend enforces the setting when turned off (APR-07/08).
- **Observation:** audit/revision immutability is enforced in application code, not by MongoDB permissions. The app database user can alter documents directly.
- **Observation:** no account lockout, 2FA or password-reset flow exists; only IP rate limiting.

6. Missing test coverage

- No automated test for gateway/restart behaviour (PERS-07) or session-expiry redirect (UI-409).
- Responsive checks exist for 4 widths but the repo has no 320 px assertion.
- No tests for receipt PDF/JPG, WebP images, time-zone/DST, token expiry, backup/restore or load.
- No test asserting that the generic form cannot create over-settlements.

7. Prioritised recommendations

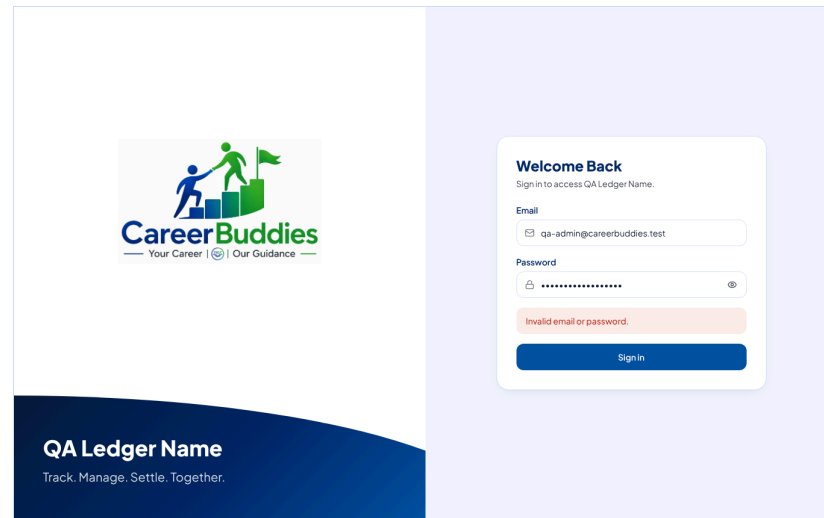
1. **Medium** — Fix gateway upstream re-resolution (PERS-07) or document restarting the whole stack.
2. **Medium** — Redirect to login when the session cannot be refreshed (UI-409).
3. **Medium** — Decide whether approving an over-settlement via the generic form should be blocked.
4. **Low** — Create rate limiters at startup (OBS-01); fix 320 px overflow (UI-102); quiet the login-page 401 console errors (UI-110).
5. **Low** — Add the missing tests listed in section 6; consider a per-founder approval permission and account lockout/2FA for production.

8. Not tested

ID	Item	Reason
NT-01	Windows PC / PowerShell / Docker Desktop behaviour	Sandbox only; the user's PC is not reachable.
NT-02	HTTPS + Secure cookies behind real TLS, production environment variables	No TLS environment; QA stack uses development settings (COOKIE_SECURE=false).
NT-03	Browsers other than Chromium; real phones/tablets; Safari	Only Playwright Chromium available.
NT-04	Screen-reader / full WCAG audit	Only keyboard focus visibility and modal focus trap were checked.
NT-05	Load, performance and large-data behaviour (1000+ transactions, many concurrent users)	Out of scope for a functional audit; only 6-way concurrency tested on recurring.
NT-06	Backup / restore and migration rollback	Destructive; not attempted on any real data.
NT-07	Receipt upload of PDF and JPG; WebP/JPG logo and photo uploads	Only PNG valid-file and spoof/oversize cases executed.
NT-08	Time-zone / DST edge cases and a moving clock	Server date fixed at 2026-10-09; only month-end anchoring tested.
NT-09	Token expiry timing (15-min access / 7-day refresh) and refresh rotation	Would require waiting out the TTLs.
NT-10	Public website hand-off careerbuddies.in/#ledger	Not deployed; only /ledger and /#ledger entry routes tested locally (UI-07).
NT-11	Ownership/equity percentage module; password reset; 2FA; email notifications; multi-currency; loan-repayment and refund linking	Features not implemented / rules undefined.
NT-12	User's real data on http://localhost:8080 (existing approved checkpoint)	Deliberately untouched; all mutations ran on an isolated throw-away stack.

9. Final readiness assessment

PASS WITH ISSUES. The accounting engine, approvals, authorization, audit trail and persistence behave correctly under 186 executed checks with no Critical/High defects. The two Medium defects affect operations/UX, not money or security; they should be fixed before relying on the app unattended or exposing it beyond the local PC. Awaiting your explicit approval before any change is made.



Evidence UI-01: login error (generic message, no leakage)


QA Ledger Name

Dashboard

Founders

Transactions

Add Transaction

Settlements

Approvals 14

Recurring & Subscriptions

Reports & Analytics

Audit Log

Settings

Docker Admin
Admin

Sign out

Reconciliation: Needs review

₹1,000.00 reimbursed by the business — borne by the business, not shared between founders. Founders share only the founder-funded part of each expense.

Needs attention: Settlements moved Deepak Sah past zero (they paid or received more than was due).

Who pays whom

The simplest set of payments that clears every balance. A suggestion is not a payment: record it once it has been paid, and it counts when it is confirmed.

Divyanshu Gautam pays → Deepak Sah ₹574.00 Record payment

Divyanshu Gautam pays → Nishant Sharma ₹113.00 Record payment

Summary

STILL TO PAY ₹687.00	STILL TO RECEIVE ₹687.00	NET SETTLEMENT ₹0.00 Receivable - payable; zero when the books balance	SETTLED SO FAR ₹6,056.66 3 payments
PAYMENTS NEEDED 2	REIMBURSED BY THE BUSINESS ₹1,000.00 Business-borne — not part of any payment above		

Evidence: Settlements page (desktop) loaded without console errors

Dashboard

Period

All time

From

mm/dd/yyyy

To

mm/dd/yyyy

Founder

All founders

Category

All categories

Reset

Showing **all time**. Totals cover approved transactions in this period. Founder balances and outstanding settlements are cumulative up to today and are not narrowed by the category filter. 14 transactions are not counted yet (awaiting approval).

1 record needs attention. [Review in Founders](#)

TOTAL BUSINESS EXPENSES

₹12,221.01

₹1,000.00 reimbursed by the business

FOUNDER CONTRIBUTIONS

₹0.00

Capital contributed by founders

Evidence: Dashboard (mobile 390 px)

10. Test matrix

Test ID	Module	Test scenario	Execution status	Result	Severity	Evidence	Recommended action
---------	--------	---------------	------------------	--------	----------	----------	--------------------

AUTO-01	Static checks	TypeScript typecheck (server + client, strict)	EXECUTED	PASS	—	npm run typecheck: no errors	None
AUTO-02	Automated tests	Existing server test suite (Vitest + supertest on real MongoDB 7)	EXECUTED	PASS	—	26 files, 403/403 tests passed	None
AUTO-03	Automated tests	Existing client test suite (Vitest + Testing Library)	EXECUTED	PASS	—	7 files, 101/101 tests passed	None
AUTO-04	Static checks	Production builds (server tsc, client Vite)	EXECUTED	PASS	—	npm run build: client built in 1.50s, no errors	None
AUTH-01	Authentication	Admin login with valid credentials returns 200 and a session cookie	EXECUTED	PASS	—	200, cookies: cb_access,cb_refresh	None
AUTH-02	Authentication	Session cookies are HttpOnly and SameSite-restricted	EXECUTED	PASS	—	cb_access=<redacted>; Max-Age=900; Path=/api; Expires=<redacted>; HttpOnly; SameSite=<redacted>; Max-Age=604800; Path=<redacted>; Expires=<redacted>; HttpOnly; SameSite=S	None
AUTH-03	Authentication	Wrong password and unknown email return the same generic 401 (no user enumeration)	EXECUTED	PASS	—	both 401: Invalid email or password	None
AUTH-04	Authentication	NoSQL-operator login payload is rejected (400)	EXECUTED	PASS	—	400	None
AUTH-05	Authentication	Unauthenticated requests to protected APIs return 401	EXECUTED	PASS	—	12 endpoints all 401	None
AUTH-06	Authentication	Unauthenticated write requests return 401 (no financial mutation without login)	EXECUTED	PASS	—	7 writes all 401	None
AUTH-07	Authentication	Tampered / garbage session token is rejected	EXECUTED	PASS	—	401	None
AUTH-08	Authentication	Logout invalidates the session; /auth/me then returns 401	EXECUTED	PASS	—	logout ok; replayed old cookie → 401	None
AUTH-09	Authentication	Password policy: short password rejected when creating a user	EXECUTED	PASS	—	400	None
AUTH-10	Authentication	Admin creates founder users; they can sign in	EXECUTED	PASS	—	2 founder users created and logged in	None
AUTH-11	Authentication	Disabled user cannot sign in, and an existing session stops working	EXECUTED	PASS	—	login=401, existing session=401	None
AUTHZ-01	Authorization	Founder role is forbidden (403) from admin-only mutations	EXECUTED	PASS	—	9 admin-only calls → 403	None
AUTHZ-02	Authorization	Founder cannot escalate by creating an admin user or changing own role	EXECUTED	PASS	—	403, role unchanged	None
CAT-01	Categories	Admin creates a category; it appears in the list	EXECUTED	PASS	—	id 6ac90f2c21c36241378330e8	None
CAT-02	Categories	Duplicate category name (case-insensitive) is rejected	EXECUTED	PASS	—	409	None
CAT-03	Categories	Empty / whitespace / over-long category names are rejected	EXECUTED	PASS	—	3 invalid names → 400	None
CAT-04	Categories	Second and third categories; reorder persists in the list order	EXECUTED	PASS	—	order Software, Hosting, Travel persisted	None
CAT-05	Categories	Invalid reorder (missing / duplicate / unknown ids) is rejected	EXECUTED	PASS	—	3 bad payloads → 400	None
FND-01	Founders	Founders list returns exactly Nishant, Deepak, Divyanshu in that order with roles	EXECUTED	PASS	—	order+roles correct	None
TXN-01	Transactions	Create expense with equal split; stored as integer minor units and Pending approval	EXECUTED	PASS	—	TXN TXN-000001; shares 33334/33334/33333	None

TXN-02	Transactions	Rounding: ₹1,000.01 split 3 ways allocates 33334/33334/33333 (sums exactly)	EXECUTED	PASS	—	33334/33334/33333	None
TXN-03	Transactions	Pending transaction is NOT counted in dashboard totals or founder positions	EXECUTED	PASS	—	totals 0 while pending	None
TXN-04	Transactions	Idempotency: replaying the same clientRequestId does not create a second transaction	EXECUTED	PASS	—	same id returned; 1 row	None
TXN-05	Transactions	Validation: amount 0, negative, fractional minor units, non-numeric, huge are rejected (400)	EXECUTED	PASS	—	6 invalid amounts → 400	None
TXN-06	Transactions	Validation: impossible/malformed dates are rejected	EXECUTED	PASS	—	6 bad dates → 400	None
TXN-07	Transactions	Validation: missing/blank description, overlong description/notes rejected	EXECUTED	PASS	—	4 cases → 400	None
TXN-08	Transactions	Validation: business expense without category, with unknown category or unknown payer is rejected	EXECUTED	PASS	—	4 cases → 400	None
TXN-09	Transactions	Unknown / extra fields (mass assignment such as status=approved, createdBy) are rejected	EXECUTED	PASS	—	all 400	None
TXN-10	Transactions	NoSQL operator objects in fields / query are rejected	EXECUTED	PASS	—	400/400	None
TXN-11	Transactions	Script/HTML text in description is stored verbatim and returned as JSON text (rendered escaped in UI — see UI-xx)	EXECUTED	PASS	—	stored as text; id 6ac90f2c21c3624137833155	None
TXN-12	Transactions	Owner can edit pending transaction with the correct version; stale version → 409	EXECUTED	PASS	—	200 then stale 409	None
TXN-13	Transactions	A different founder (non-owner) cannot edit the transaction	EXECUTED	PASS	—	403	None
TXN-14	Transactions	Hard DELETE of a transaction is not possible	EXECUTED	PASS	—	405; record intact	None
TXN-15	Transactions	Edit changes amount and the split re-allocates consistently	EXECUTED	PASS	—	split re-summed to 100000	None
TXN-16	Transactions	Receipt upload: valid PNG accepted; spoofed file (HTML as .png) and oversize rejected	EXECUTED	PASS	—	valid 201, spoof 415, oversize 413	None
TXN-17	Transactions	Receipts are not publicly reachable without sign-in	EXECUTED	PASS	—	401 anonymous	None
TXN-18	Transactions	List filters (status/type/search/date) and pagination work and total is consistent	EXECUTED	PASS	—	pageSize cap behaviour: 400	None
APR-01	Approvals	Approving a pending expense makes it count: dashboard total, founder paid and fair shares update	EXECUTED	PASS	—	total ₹1,000.01; A paid 100001 fair 33334; Σnet=0	None
APR-02	Approvals	Founder net positions sum to zero and settlement suggestions equal what is owed	EXECUTED	PASS	—	transfers total 66667 (= 33334+33333)	None
APR-03	Approvals	Approve is idempotent-safe: approving an already	EXECUTED	PASS	—	409	None

		approved transaction is rejected, not double-counted					
APR-04	Approvals	Approve with stale version → 409	EXECUTED	PASS	—	409	None
APR-05	Approvals	Reject moves pending → rejected and does not count	EXECUTED	PASS	—	rejected; not counted; re-approve 409	None
APR-06	Approvals	Approvals queue lists pending items with accurate counts	EXECUTED	PASS	—	pending count 2 matches list	None
APR-07	Approvals	Approval rule enforced by BACKEND: allowSelfApproval=false blocks approving own transaction	EXECUTED	PASS	—	self → 403; other founder → 200	Observation: self-approval is ON by default (a policy choice); the backend enforces the switch when turned off.
APR-08	Approvals	Approval rule enforced by BACKEND: requireRejectionReason=true rejects a reject without a comment	EXECUTED	PASS	—	400 without comment, 200 with	None
APR-09	Approvals	Non-admin founder may approve others' pending transactions (per product plan); anonymous may not	EXECUTED	PASS	—	anon 401; founder 200 (any founder is an approver by design)	Observation: every signed-in founder can approve any pending transaction (per product plan); there is no per-founder approval permission.
APR-10	Approvals	Voiding an approved expense (admin) reverses its effect on all totals	EXECUTED	PASS	—	total 750001→700001	None
AUTHZ-03	Authorization	Founder cannot void another user's transaction nor reverse settlements (admin-only)	EXECUTED	PASS	—	403; record still approved	None
REIM-01	Reimbursement (Option C)	Setup: approved ₹3,000 expense paid by Nishant; reimbursable list shows ₹3,000 remaining	EXECUTED	PASS	—	remaining 300000	None
REIM-02	Reimbursement (Option C)	Reimbursement without a linked expense is rejected	EXECUTED	PASS	—	400	None
REIM-03	Reimbursement (Option C)	Partial reimbursement ₹1,000 approved: founder-funded = ₹2,000; fair shares computed on ₹2,000	EXECUTED	PASS	—	reimbursed 100000; A founder-funded 901001	None
REIM-04	Reimbursement (Option C)	Second reimbursement ₹1,500 OK; third ₹600 exceeding remaining ₹500 is rejected	EXECUTED	PASS	—	excess → 400; exact remaining 500 → 201 (pending)	None
REIM-05	Reimbursement (Option C)	Pending reservation counts: another reimbursement beyond remaining capacity is refused until the pending one is rejected	EXECUTED	PASS	—	reservation blocks then releases on reject	None
REIM-06	Reimbursement (Option C)	An expense with active reimbursements cannot be voided	EXECUTED	PASS	—	409	None
REIM-07	Reimbursement (Option C)	Voiding a reimbursement restores the reimbursable capacity and the founder-funded figure	EXECUTED	PASS	—	founder-funded 751001→901001	None
REIM-08	Reimbursement (Option C)	Reimbursement paid-by must equal the expense payer; unapproved/other-founder expense link rejected	EXECUTED	PASS	—	400/400	None
SET-01	Settlements	Suggestions balance: Σ payable = Σ receivable and reconciliation PASS after the above activity	EXECUTED	PASS	—	{"settledMinor":0,"outstandingPayableMinor":600666,"outstandingReceivableMinor":600666,"netSettlementMinor":0,"recommendedTransfersMinor":600666,"businessBorneMinor":1000	None

SET-02	Settlements	Record payment creates a PENDING settlement that does not change balances yet	EXECUTED	PASS	—	pending, settledMinor unchanged	None
SET-03	Settlements	Duplicate identical pending settlement is rejected (409)	EXECUTED	PASS	—	409	None
SET-04	Settlements	Settlement larger than the amount owed is rejected	EXECUTED	PASS	—	400 EXCEEDS_OUTSTANDING	None
SET-05	Settlements	Payer = receiver, zero/negative/fractional amounts and impossible dates are rejected	EXECUTED	PASS	—	5 invalid → 400	None
SET-06	Settlements	Confirming (approving) the settlement reduces outstanding by exactly that amount	EXECUTED	PASS	—	settled +10000; outstanding –10000	None
SET-07	Settlements	Reversing (voiding) a confirmed settlement restores the original suggestion; founder cannot reverse	EXECUTED	PASS	—	reversed; balances restored	None
SET-08	Settlements	Full settlement of all suggestions yields zero outstanding and "settled" state for every founder	EXECUTED	PASS	—	outstanding 0 / 0 after settling all suggestions	None
SET-09	Settlements	Over-settlement via the generic transaction form is flagged by the engine (not silently accepted as balanced)	EXECUTED	PASS	—	approve=200; over-settlement fields present in positions: true; reconciliation=REVIEW	Observation: the generic Add Transaction form lets a settlement larger than the amount owed be approved; the engine flags it (reconciliation = REVIEW,
CAT-06	Categories	Renaming a category keeps its transaction associations; history shows the new name	EXECUTED	PASS	—	category id same, name updated in transaction view	None
CAT-07	Categories	Deactivated category is refused for NEW transactions but old ones remain intact and editable view	EXECUTED	PASS	—	new tx 400; history intact; report categories: 1	None
CAT-08	Categories	Reactivating a category allows new transactions again	EXECUTED	PASS	—	201	None
CAT-09	Categories	Renaming to an existing name is rejected	EXECUTED	PASS	—	409	None
CAT-10	Categories	Categories cannot be hard-deleted	EXECUTED	PASS	—	404	None
FND-02	Founders	Admin edits founder name/role; change persists and shows in dashboard; historical transactions unchanged	EXECUTED	PASS	—	role updated + restored	None
FND-03	Founders	Reordering founders is reflected in founders list and dashboard, then restored	EXECUTED	PASS	—	order propagated & restored	None
FND-04	Founders	Founder photo: valid PNG accepted; spoofed file rejected; photo requires sign-in; delete works	EXECUTED	PASS	—	ok / spoof rejected / anon 401 / delete ok	None
FND-05	Founders	Inactive founder is excluded from new transactions but historical records stay	EXECUTED	PASS	—	inactive payer → 400	None
FND-06	Founders	Founder profile validation: blank / overlong name, bad email, share >100 rejected	EXECUTED	PASS	—	4 → 400	None
FND-07	Founders	Founder "ownership" / equity fields: only defaultSharePercent exists;	NOT TESTED	NOT TESTED	—	Feature not implemented: no ownership/equity-percentage module exists (only defaultSharePercent on the founder profile, unused for accounting). No assertion executed.	—

		no ownership-percentage module					
SETT-01	Settings (all sections)	GET settings returns every section + read-only reimbursement/calculation policy	EXECUTED	PASS	—	sections: business,regional,dashboard,approvals,settlements,recurring,reports,branding,version	None
SETT-02	Business profile	Change business names → persisted, version bumped, served via /config and public branding	EXECUTED	PASS	—	persisted; config + public updated	None
SETT-03	Business profile	Invalid names (1 char, 200 chars, "<script>", control chars) are rejected	EXECUTED	PASS	—	4 invalid → 400	None
SETT-04	Settings (all sections)	Stale expectedVersion → 409 and nothing changes	EXECUTED	PASS	—	409; value unchanged	None
SETT-05	Settings (all sections)	Unknown keys and attempts to edit read-only policy (reimbursement/calculation) are rejected	EXECUTED	PASS	—	5 → 400; policy stays read-only	None
SETT-06	Settings (all sections)	Empty PATCH (no settings) is rejected	EXECUTED	PASS	—	400	None
SETT-07	Currency & regional	Locale/timezone change persists; invalid locale/timezone rejected	EXECUTED	PASS	—	persisted, invalid rejected, restored	None
SETT-08	Currency & regional	Currency itself (INR, 2 minor units) is fixed and not editable via settings	EXECUTED	PASS	—	currency not a setting (400)	None
SETT-09	Approval rules	Approval rule toggles persist and are echoed by /config	EXECUTED	PASS	—	{"allowSelfApproval":false,"requireRejectionReason":true} → restored	None
SETT-10	Settlement preferences	Payment methods list: update persists; empty list, >12, blank or overlong entries rejected	EXECUTED	PASS	—	ok + 4 invalid → 400; restored	None
SETT-11	Recurring payment settings	reminderDaysAhead changes the due-soon window (0, 61 rejected)	EXECUTED	PASS	—	bounds enforced; list uses setting	None
SETT-12	Dashboard preferences	recentTransactionsCount limits the dashboard recent list; bounds enforced	EXECUTED	PASS	—	bounds + effect verified	None
SETT-13	Calculation & reporting	fiscalYearStartMonth changes annual grouping labels in reports	EXECUTED	PASS	—	2026-27 → 2026	None
SETT-14	User access	Admin lists users; role/status change is audited; password hash never returned	EXECUTED	PASS	—	4 users, no secrets in payload	None
BRAND-01	Branding & logo	Admin uploads a valid logo; /api/branding/logo serves it; persists in settings	EXECUTED	PASS	—	logoVersion 1	None
BRAND-02	Branding & logo	Spoofed/oversized/empty logo is rejected; existing logo is unchanged	EXECUTED	PASS	—	415/413/400/415	None
BRAND-03	Branding & logo	Logo alt text editable & validated; delete restores the default logo	EXECUTED	PASS	—	custom logo removed → default	None
REC-01	Recurring	Create a recurring payment; appears in list with correct status/summary and monthly commitment	EXECUTED	PASS	—	commitment 140000; overdue 1; dueSoon 1	None
REC-02	Recurring	Validation: bad frequency, zero amount, bad date, empty provider, empty/duplicate split, inactive/unknown founder	EXECUTED	PASS	—	9 invalid → 400	None
REC-03	Recurring	Recording a due payment creates exactly one PENDING transaction (not counted	EXECUTED	PASS	—	txn TXN-000022; next due 2026-11-01	None

		until approved) and advances next due date					
REC-04	Recurring	Recording the SAME due date again does not create a duplicate transaction (replay returns the existing one or is refused)	EXECUTED	PASS	—	200 (idempotent replay: same transaction TXN-000022); transactions 1→1	None
REC-05	Recurring	Concurrency: 6 simultaneous record requests for one due date create at most ONE transaction	EXECUTED	PASS	—	statuses 201,409,200,409,409,200; transactions=1	None
REC-06	Recurring	Month-end anchoring: monthly payment due 31 Jan advances to 28 Feb (2027) then back to 31 Mar	EXECUTED	PASS	—	2027-02-28 → 2027-03-31	None
REC-07	Recurring	Pause blocks recording; resume allows it; cancel is final (no edit/record)	EXECUTED	PASS	—	paused-record 409; cancelled edit 409, record 409	None
REC-08	Recurring	Stale version on edit/pause → 409; recurring cannot be hard-deleted	EXECUTED	PASS	—	stale 409; delete 404	None
REC-09	Recurring	Recorded recurring transaction goes through approval and then counts once in totals	EXECUTED	PASS	—	+120000 once	None
REP-01	Reports	Report totals equal dashboard KPIs and founder-position sums (reconciliation)	EXECUTED	PASS	—	total 1121001; ΣfairShare 1021001; Σpaid 1021001; Σcategories 1121001; Σmonthly 1121001	None
REP-02	Reports	Filters: founder / category / date range narrow results; reversed range and operator injection rejected	EXECUTED	PASS	—	filters ok; invalid → 400	None
REP-03	Reports	CSV export for every kind: correct content-type, header row, UTF-8 BOM; bad kind rejected	EXECUTED	PASS	—	summary:11rows transactions:26rows monthly:2rows categories:2rows founders:5rows settlements:5rows	None
REP-04	Reports	CSV formula-injection guard: a description starting with "=" / "+" / "@" is neutralised	EXECUTED	PASS	—	2026-10-09,TXN-000029,Business Expense,"=HYPERLINK("http://evil","x"),QA Hosting,Nishant Sharm	None
REP-05	Reports	Monthly/annual/category sections each sum to the total (no double counting) when approved data exists	EXECUTED	PASS	—	all three = 1121001	None
AUD-01	Audit log	Audit log is admin-only, paginated and filterable by action	EXECUTED	PASS	—	18 SETTINGS_CHANGED events	None
AUD-02	Audit log	Key actions are recorded: login, transaction create/approve/void, category, founder, settings, recurring, settlement	EXECUTED	PASS	—	13 action types present	None
AUD-03	Audit log	Audit entries carry actor, timestamp, entity and before/after for settings and category rename	EXECUTED	PASS	—	actor=Docker Admin <qa-admin@careerbuddies.test>; fields=id,at,actor,actorId,action,entityType,entityId,summary,before,after,reason	None
AUD-04	Audit log	Audit log never contains passwords, hashes, tokens	EXECUTED	PASS	—	scanned 100 events	None
AUD-05	Audit log	Audit log is append-only: no API to edit/delete events	EXECUTED	PASS	—	404/404/404/404	None
AUD-06	Audit log	Failed login attempt is audited without the attempted password	EXECUTED	PASS	—	4 LOGIN_FAILED events, no password	None
SEC-01	Security & errors	Security headers present (nosniff, frame protection, no x-powered-by)	EXECUTED	PASS	—	nosniff; frame: SAMEORIGIN	None
SEC-02	Security & errors	Malformed JSON → 400 JSON error without stack trace	EXECUTED	PASS	—	400 {"error":{"code":"INVALID_JSON","message":"Malformed JSON body"}}	None

SEC-03	Security & errors	Unknown API route → 404 JSON; invalid Objectid → 400 (not 500)	EXECUTED	PASS	—	404/400/404	None
SEC-04	Security & errors	Oversized JSON body rejected (413) instead of processed	EXECUTED	PASS	—	413	None
SEC-05	Security & errors	CORS: foreign Origin does not receive Access-Control-Allow-Origin	EXECUTED	PASS	—	CAAO=http://localhost:8090	None
SEC-06	Security & errors	CSRF: cross-site write with valid cookie is mitigated (foreign Origin blocked OR cookies SameSite=Strict/Lax)	EXECUTED	PASS	—	foreign-Origin write → 403 (reached handler: false); cookies SameSite restricted: true ()	None
SEC-07	Security & errors	Founder user cannot read another section's admin data via ID guessing (users list, audit)	EXECUTED	PASS	—	403	None
SEC-08	Security & errors	Passwords stored hashed in MongoDB (no plaintext) and secrets not in API output	EXECUTED	PASS	—	4 users; hash prefix \$2b\$... length 60	None
PERS-01	Persistence	All data survives restarting ALL containers (transactions, categories, settings, founders, recurring, balances)	EXECUTED	PASS	—	snapshot identical (2713 bytes) after full restart	None
PERS-06	Persistence	Restarting only the API container: the web gateway (nginx) recovers without restarting it (no lasting 502)	EXECUTED	PASS	—	recovered on its own	None
PERS-07	Persistence	Restarting API and database together (compose restart server mongo): gateway still reaches the API afterwards	EXECUTED	FAIL	Medium	gateway returned errors for 70s after API+DB restart (API ip 172.19.0.4; nginx upstream-connect failures logged: 36); recovered only after restarting the client container	Make nginx re-resolve the API host (resolver 127.0.0.11 + variable proxy_pass) or add a healthcheck/depends_on restart for the client; document `docke
PERS-02	Persistence	Sessions: after restarts the cookie session still works or cleanly requires login (no 500)	EXECUTED	PASS	—	/auth/me → 200	None
PERS-03	Persistence	Settings/categories/audit live in MongoDB collections (not memory): direct DB check	EXECUTED	PASS	—	{"settings":1,"cats":3,"audit":117,"tx":26,"rev":48}	None
PERS-04	Persistence	Hard deletes and updates of audit/revision collections are blocked at model level (code) — DB-level immutability is not enforced	NOT TESTED	NOT TESTED	—	Design observation only: audit/revision immutability is enforced by application hooks, not by DB permissions. No assertion executed.	—
PERS-05	Persistence	DB outage handling: API returns a clean 5xx/health "disconnected" (not a crash) when MongoDB is stopped, and recovers	EXECUTED	PASS	—	during outage health=503 {"status":"degraded","db":"disconnected","uptimeSeconds":78}; /transactions=500; recovered; login after=200	None
SEC-09	Security & errors	API rate limiting on login: repeated failures are throttled (429)	EXECUTED	PASS	—	429 after 10 attempts	None
STAT-01	Dead controls (static scan)	Every <button> in the client source has an onClick, is a submit button, or is explicitly disabled/aria-controlled (no visible-but-inert buttons)	EXECUTED	PASS	—	69 <button> elements scanned, all wired	None
STAT-02	Dead controls (static scan)	No placeholder/dummy links (href="#"), TODO/"coming soon" text or hard-coded demo data in the UI source	EXECUTED	PASS	—	none found	None
STAT-03	In-memory state (static scan)	Server holds no business data in process memory (no module-level Maps/arrays	EXECUTED	PASS	—	module-level collections: /middleware/originCheck.ts: const SAFE_METHODS = new Set	None

		used as stores); only rate-limiter and lazy caches					
UI-01	Authentication (UI)	Login page: empty submit shows field messages; wrong password shows error; no stack/DB text leaked	EXECUTED	PASS	—	Invalid email or password.	None
UI-02	Authentication (UI)	Valid login lands on Dashboard; Sign out returns to Login and blocks back-navigation to data	EXECUTED	PASS	—	sign out → /login; direct /dashboard returns to /login	None
UI-03	Route protection	Signed-out visit to every app route redirects to /login (no data flash)	EXECUTED	PASS	—	10 routes → /login	None
UI-04	Route protection	Founder (non-admin) cannot see Audit Log link and is redirected away from /audit-log	EXECUTED	PASS	—	nav hidden; /audit-log redirected to /dashboard	None
UI-05	Route protection	Founder opening /settings: no ability to change settings (controls hidden/blocked) and API enforces 403	EXECUTED	PASS	—	url /dashboard; editable=false	None
UI-06	Route protection	Unknown URL (/does-not-exist) shows the app safely (redirect) rather than a blank/crash page	EXECUTED	PASS	—	redirected to dashboard	None
UI-100	Page: Dashboard	Loads at 4 viewports (1366/820/390/320): no console errors, no failed API calls, no horizontal overflow	EXECUTED	PASS	—	clean at 4 viewports	None
UI-101	Page: Founders	Loads at 4 viewports (1366/820/390/320): no console errors, no failed API calls, no horizontal overflow	EXECUTED	PASS	—	clean at 4 viewports	None
UI-102	Page: Transactions	Loads at 4 viewports (1366/820/390/320): no console errors, no failed API calls, no horizontal overflow	EXECUTED	FAIL	Low	narrow: horizontal overflow 21px	Constrain the mobile transaction-card amount/row (min-w-0, allow wrapping) so nothing exceeds 320px.
UI-103	Page: Settlements	Loads at 4 viewports (1366/820/390/320): no console errors, no failed API calls, no horizontal overflow	EXECUTED	PASS	—	clean at 4 viewports	None
UI-104	Page: Approvals	Loads at 4 viewports (1366/820/390/320): no console errors, no failed API calls, no horizontal overflow	EXECUTED	PASS	—	clean at 4 viewports	None
UI-105	Page: Recurring	Loads at 4 viewports (1366/820/390/320): no console errors, no failed API calls, no horizontal overflow	EXECUTED	PASS	—	clean at 4 viewports	None
UI-106	Page: Reports	Loads at 4 viewports (1366/820/390/320): no console errors, no failed API calls, no horizontal overflow	EXECUTED	PASS	—	clean at 4 viewports	None
UI-107	Page: Audit Log	Loads at 4 viewports (1366/820/390/320): no console errors, no failed API calls, no horizontal overflow	EXECUTED	PASS	—	clean at 4 viewports	None
UI-108	Page: Settings	Loads at 4 viewports (1366/820/390/320): no console errors, no failed API calls, no horizontal overflow	EXECUTED	PASS	—	clean at 4 viewports	None
UI-109	Page: Add Transaction	Loads at 4 viewports (1366/820/390/320): no console errors, no failed API calls, no horizontal overflow	EXECUTED	FAIL	Low	narrow: horizontal overflow 21px	Same root cause as UI-102 (transactions list rendered behind the Add Transaction route).

UI-110	Console errors	Signed-out login page produces no console errors	EXECUTED	FAIL	Low	2 console error(s): Failed to load resource: the server responded with a status of 401 (Unauthorized) Failed to load resource: the server responded with a status of 401	Avoid probing /auth/me and /auth/refresh with console-visible 401s on the login page (use a lightweight session-hint endpoint or handle quietly).
UI-111	Responsive	Mobile: hamburger opens the navigation drawer; choosing a page navigates and closes it	EXECUTED	PASS	—	drawer ok	None
UI-200	Settings (UI)	All 12 settings sections open and render content (no blank/error panels)	EXECUTED	PASS	—	12 sections rendered	None
UI-201	Settings (UI): Business profile (display name)	Change "Business profile (display name)", Save shows success only after server save, persists after reload, Cancel reverts	EXECUTED	PASS	—	persisted QA UI Ledger; restored QA Ledger Name	None
UI-202	Settings (UI): Currency and regional (number format)	Change "Currency and regional (number format)", Save shows success only after server save, persists after reload, Cancel reverts	EXECUTED	PASS	—	persisted en-GB; restored en-IN	None
UI-203	Settings (UI): Approval rules (require rejection reason)	Change "Approval rules (require rejection reason)", Save shows success only after server save, persists after reload, Cancel reverts	EXECUTED	PASS	—	persisted true; restored false	None
UI-204	Settings (UI): Recurring payments (reminder days)	Change "Recurring payments (reminder days)", Save shows success only after server save, persists after reload, Cancel reverts	EXECUTED	PASS	—	persisted 12; restored 7	None
UI-205	Settings (UI): Dashboard display (recent transactions)	Change "Dashboard display (recent transactions)", Save shows success only after server save, persists after reload, Cancel reverts	EXECUTED	PASS	—	persisted 8; restored 10	None
UI-206	Settings (UI): Calculation and reporting (financial year start)	Change "Calculation and reporting (financial year start)", Save shows success only after server save, persists after reload, Cancel reverts	EXECUTED	PASS	—	persisted 1; restored 4	None
UI-207	Settings (UI): Settlement preferences	Add and remove a payment method; persists; shows in Record payment/Add transaction method list	EXECUTED	PASS	—	added, persisted, removed	None
UI-208	Settings (UI)	Invalid input (1-char name; reminder days = 0/abc) shows a clear message and does not save	EXECUTED	PASS	—	blocked with message	None
UI-209	Settings (UI)	Unsaved-change guard: navigating away from a dirty settings form asks for confirmation	EXECUTED	PASS	—	You have unsaved changes. Leave without saving?	None
UI-210	Settings (UI): Reimbursement/calculation policy	Policy sections are read-only (no editable controls) and match the API policy text	EXECUTED	PASS	—	no editable controls	None
UI-211	Settings (UI): Branding	Upload a logo via the UI: shows in sidebar & login; invalid file rejected with message; remove restores default	EXECUTED	PASS	—	sidebar /api/branding/logo?v=5; login /api/branding/logo?v=5	None
UI-300	Transactions (UI)	Add Transaction modal: required-field messages; success banner only AFTER server save; list shows new row	EXECUTED	PASS	—	saved; ₹1,234.56 listed	None

UI-301	Transactions (UI)	Server failure (500) while saving: no success message, modal stays open, values preserved	EXECUTED	PASS	—	error shown; values kept	None
UI-302	Transactions (UI)	Network offline while saving: friendly error, modal open, nothing created	EXECUTED	PASS	—	message: Could not reach the server	None
UI-303	Transactions (UI)	Script/HTML in a description is rendered as inert text everywhere (list, detail, dashboard, approvals, audit) — no dialog fires	EXECUTED	PASS	—	no script execution; 6 pages checked	None
UI-304	Transactions (UI)	Edit page for a pending transaction: saves changes, shows success after server save, stale edit shows conflict	EXECUTED	PASS	—	saved; stale edit blocked with message	None
UI-305	Categories (UI)	Inactive category is absent from the Add Transaction category list; renamed category appears with new name	EXECUTED	PASS	—	inactive hidden from form	None
UI-306	Categories (UI)	Settings → Categories: add, rename, deactivate, reorder buttons work and persist	EXECUTED	PASS	—	add/rename/deactivate persisted	None
UI-400	Dashboard (UI)	Dashboard KPI numbers equal the API values; founder overview order Nishant → Deepak → Divyanshu	EXECUTED	PASS	—	KPI ₹12,221.01 matches; founder order ok	None
UI-401	Dashboard (UI)	Dashboard filters (founder / category / period) re-query and change the figures; Reset restores	EXECUTED	PASS	—	filter changes figures; reset restores	None
UI-402	Founders (UI)	Founders page shows the 3 founders in order with roles; profile ledger page opens and balances match the API	EXECUTED	PASS	—	order and profile ok	None
UI-403	Approvals (UI)	Approvals page: Approve and Reject dialogs work and persist to the database	EXECUTED	PASS	—	approve/reject persisted to DB	None
UI-404	Settlements (UI)	Record Payment dialog: validates amount > outstanding; valid payment creates a pending settlement; Approve confirms; Reverse restores	EXECUTED	PASS	—	over-amount blocked; pending → +₹100 on approve → restored on reverse	None
UI-405	Recurring (UI)	Recurring page: add form validation; add works; Pause/Resume/Cancel buttons change status; double-click Record creates one transaction	EXECUTED	PASS	—	validation ok; pause/resume ok; triple-click record → 1 txn	None
UI-406	Reports (UI)	Reports page: totals match API; filter changes figures; each CSV download button returns a file	EXECUTED	PASS	—	6 CSV files downloaded with content	None
UI-407	Audit log (UI)	Audit log page lists events newest first, filter works, shows actor and summary	EXECUTED	PASS	—	rendered 4476 chars	None
UI-408	Error states (UI)	API failure on Dashboard shows an error box with Retry; Retry recovers	EXECUTED	PASS	—	error + retry works	None
UI-409	Auth (UI)	Session expiry mid-use: clearing cookies then clicking a nav item sends the user to login (no blank page / infinite spinner)	EXECUTED	FAIL	Medium	stuck at http://localhost:8090/founders: QA Ledger Name Dashboard Founders Transactions Add Transaction Settlements Approvals 19 Recurring & Subscriptions Repor	On a 401 that survives the refresh attempt, clear client auth state and navigate to /login with a "session expired" message.

UI-410	Persistence (UI)	Page refresh keeps the user signed in and the same data (dashboard totals identical)	EXECUTED	PASS	—	identical after reload	None
UI-411	UI quality	Page titles update per page and use the configured business name	EXECUTED	PASS	—	Dashboard · QA Ledger Name Founders · QA Ledger Name Settlements · QA Ledger Name	None
UI-412	UI quality	Keyboard: Tab order reaches the main nav and a primary action; focus ring is visible on focused controls	EXECUTED	PASS	—	12 tab stops, all with focus indicator	None
UI-07	Portal entry (UI)	Website entry route: /ledger and /#ledger land on login when signed out and on the dashboard when signed in	EXECUTED	PASS	—	both entry forms route correctly	None
OBS-01	Server logs	API log is free of framework validation errors / stack traces during normal use	EXECUTED	FAIL	Low	33 express-rate-limit "ERR_ERL_CREATED_IN_REQUEST_HANDLER" validation errors (limiter instances are created lazily inside a request handler); 0 uncaught exceptions. Limit	Create the express-rate-limit instances at app start-up instead of lazily inside request handlers (silences 33 logged validation errors; behaviour is
NT-01	—	Windows PC / PowerShell / Docker Desktop behaviour	NOT TESTED	NOT TESTED	—	Sandbox only; the user's PC is not reachable.	See section 8
NT-02	—	HTTPS + Secure cookies behind real TLS, production environment variables	NOT TESTED	NOT TESTED	—	No TLS environment; QA stack uses development settings (COOKIE_SECURE=false).	See section 8
NT-03	—	Browsers other than Chromium; real phones/tablets; Safari	NOT TESTED	NOT TESTED	—	Only Playwright Chromium available.	See section 8
NT-04	—	Screen-reader / full WCAG audit	NOT TESTED	NOT TESTED	—	Only keyboard focus visibility and modal focus trap were checked.	See section 8
NT-05	—	Load, performance and large-data behaviour (1000+ transactions, many concurrent users)	NOT TESTED	NOT TESTED	—	Out of scope for a functional audit; only 6-way concurrency tested on recurring.	See section 8
NT-06	—	Backup / restore and migration rollback	NOT TESTED	NOT TESTED	—	Destructive; not attempted on any real data.	See section 8
NT-07	—	Receipt upload of PDF and JPG; WebP/JPG logo and photo uploads	NOT TESTED	NOT TESTED	—	Only PNG valid-file and spoof/oversize cases executed.	See section 8
NT-08	—	Time-zone / DST edge cases and a moving clock	NOT TESTED	NOT TESTED	—	Server date fixed at 2026-10-09; only month-end anchoring tested.	See section 8
NT-09	—	Token expiry timing (15-min access / 7-day refresh) and refresh rotation	NOT TESTED	NOT TESTED	—	Would require waiting out the TTLs.	See section 8
NT-10	—	Public website hand-off careerbuddies.in/#ledger	NOT TESTED	NOT TESTED	—	Not deployed; only /ledger and /#ledger entry routes tested locally (UI-07).	See section 8
NT-11	—	Ownership/equity percentage module; password reset; 2FA; email notifications; multi-currency; loan-repayment and refund linking	NOT TESTED	NOT TESTED	—	Features not implemented / rules undefined.	See section 8
NT-12	—	User's real data on http://localhost:8080 (existing approved checkpoint)	NOT TESTED	NOT TESTED	—	Deliberately untouched; all mutations ran on an isolated throw-away stack.	See section 8